BancoCN — Relatório de laboratório de Pentest Web

Autor: Fábio Cavalcante
Período documentado: outubro de 2026
Tipo de atividade: estudo prático em ambiente apresentado como educacional
Foco: reconhecimento, SQL Injection e upload inseguro de arquivos

> **Nota de escopo:** este é um *write-up* de laboratório, não um pentest contratado nem uma auditoria completa. O domínio original, o conteúdo de credenciais e os parâmetros de exploração foram omitidos da versão pública. Não há evidência no material fornecido de acesso `root` ou de elevação de privilégios.

1. Resumo executivo

Durante a análise do laboratório BancoCN, documentei atividades de reconhecimento passivo e ativo e dois achados principais:

- **Injeção SQL (SQL Injection, técnica UNION-based):** um parâmetro de URL apresentou erro de sintaxe SQL e, em testes posteriores, a aplicação exibiu dados associados a uma conta administrativa, incluindo um hash de senha. O hash e qualquer senha recuperada **não são publicados**.
- **Upload inseguro de arquivos com execução remota de comandos (RCE):** a área administrativa permitiu o envio de um arquivo com extensão `.php5`. A execução do comando de verificação `whoami` retornou `www-data` no navegador, demonstrando execução no contexto da conta do serviço web.

Os dois achados foram observados no mesmo laboratório. **O material não demonstra, passo a passo, que o primeiro achado era necessário para alcançar o segundo**, portanto não afirmo uma cadeia causal completa.

2. Objetivo e metodologia

O objetivo foi praticar identificação, validação e documentação de falhas comuns em aplicações web. As atividades registradas foram:

1. **Reconhecimento passivo:** consulta WHOIS e buscas indexadas usando Google Dorking.
2. **Levantamento de superfície:** consulta ao `robots.txt` e observação das rotas `/assets`, `/classes`, `/images` e `/admin`.
3. **Identificação de tecnologias:** uso do Wappalyzer e observação das mensagens retornadas pela aplicação. A extensão indicou MySQL, enquanto uma mensagem de erro mencionou MariaDB; esses indícios não substituem confirmação da configuração do servidor.
4. **Validação da SQL Injection:** observação de erro de sintaxe seguida de uma resposta compatível com a técnica UNION-based, expondo dados de usuário no laboratório.
5. **Avaliação do upload:** verificação do comportamento de aceitação de arquivos, com relato de rejeição da extensão `.php` e aceitação de `.php5`.
6. **Comprovação da execução:** retorno de `www-data` à execução de `whoami` em arquivo acessível pela aplicação.

Observações que não são falhas por si só

- **Cloudflare:** sua presença foi observada, mas **não comprova** que um WAF esteja ativado.
- **Rota `/admin` em `robots.txt`:** a existência e divulgação de um endereço administrativo **não constituem, isoladamente, vulnerabilidade crítica**; isso exige evidências de falta de controle de acesso ou outra falha.

- **Diretórios indexados:** os resultados do Google indicaram a exposição de caminhos e possíveis listagens. O impacto depende do conteúdo efetivamente acessível e não foi demonstrado nesta documentação.

3. Achados

BCN-01 — SQL Injection com exposição de dados

Campo	Descrição
Categoria	SQL Injection — indícios de exploração UNION-based
Severidade	**Alta (estimativa qualitativa, sem CVSS formal)**
Superfície	Parâmetro de URL de página da aplicação
Evidência	Mensagem de erro SQL e captura de dados de conta administrativa exibidos na resposta
Impacto observado	Divulgação de informações associadas a uma conta administrativa, incluindo hash de senha

Análise: o retorno de erro SQL durante a manipulação de um parâmetro motivou novos testes. A evidência posterior mostra dados devolvidos à página, compatíveis com uma exploração baseada em `UNION`. O relatório original descreve o hash como MD5; **o formato exibido não confirma sozinho o algoritmo usado no armazenamento**.

Mitigações recomendadas: consultas parametrizadas; validação de entradas; mensagens de erro genéricas ao público; princípio do menor privilégio no acesso ao banco; armazenamento de senhas com algoritmos próprios para senhas, como Argon2id ou bcrypt, após análise da implementação.

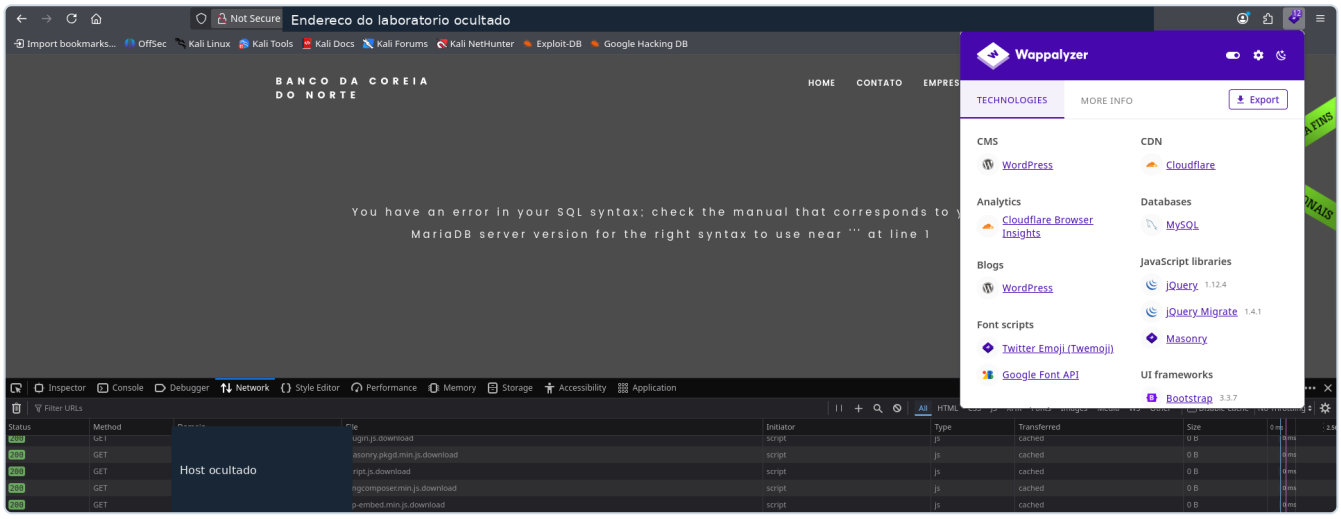


Figura 1 — Mensagem de erro SQL e identificação de tecnologias. Endereço de laboratório ocultado.

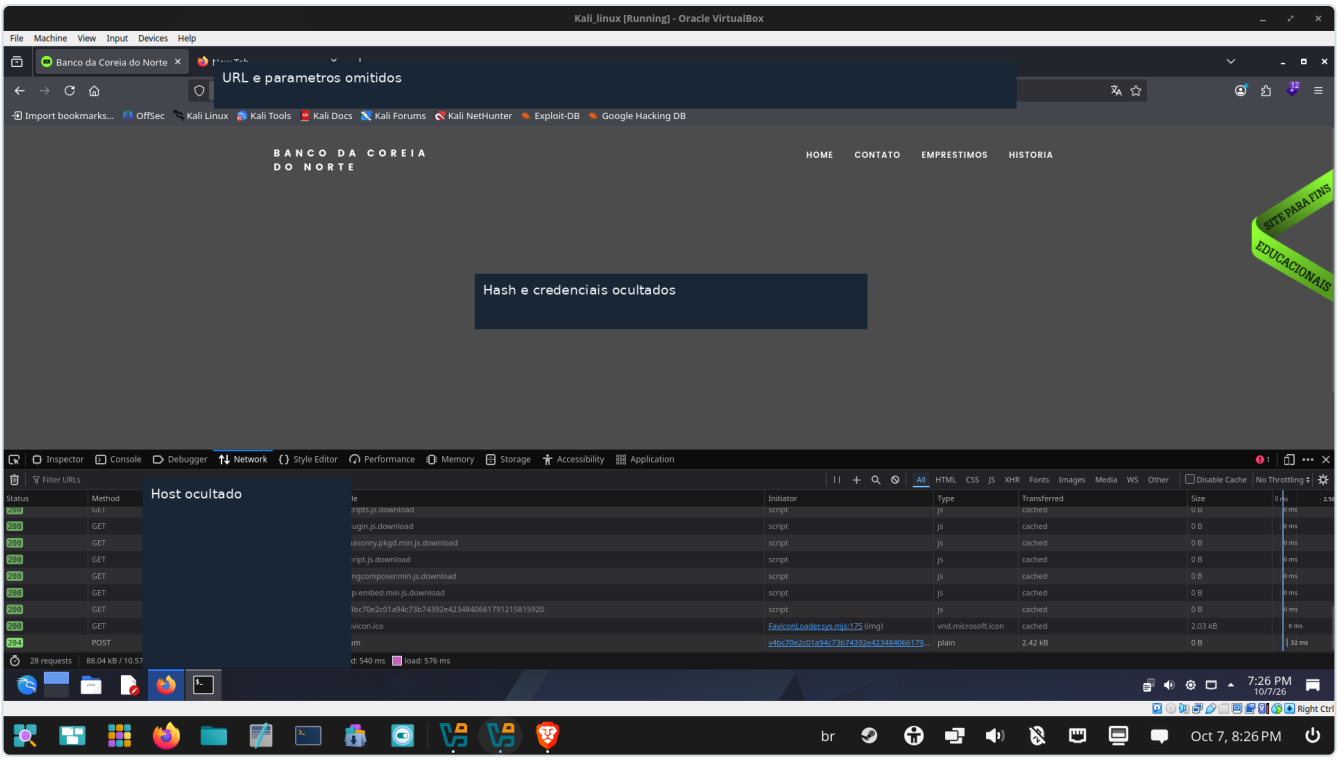


Figura 2 — Resposta com dados de conta em um teste UNION-based. URL, domínio e material de credencial ocultados.

BCN-02 — Upload inseguro permitindo execução de comandos

Campo	Descrição
Categoria	Upload inseguro de arquivo executável / RCE
Severidade	**Crítica (estimativa qualitativa, condicionada ao escopo e privilégios)**
Superfície	Recurso de upload na área administrativa
Evidência	Arquivo `.php5` aceito e acessado pela aplicação; `whoami` retornou `www-data`
Impacto observado	Execução remota de comandos com privilégios da conta do servidor web

Análise: segundo os testes registrados, um arquivo com extensão `.php` não executou como esperado, enquanto a variante `.php5` pôde ser utilizada. A captura posterior mostra o resultado `www-data` após o comando de verificação, corroborando a execução de comandos no contexto do serviço web. **Não houve demonstração de acesso `root`, persistência ou movimentação lateral**.

Mitigações recomendadas: lista restrita de tipos de arquivo aceitos; validação do conteúdo real além da extensão; armazenamento fora do diretório público; bloqueio explícito da execução de scripts em diretórios de upload; nomes de arquivo gerados pelo servidor; permissões mínimas e revisão do tratamento de uploads pela aplicação e pelo servidor web.

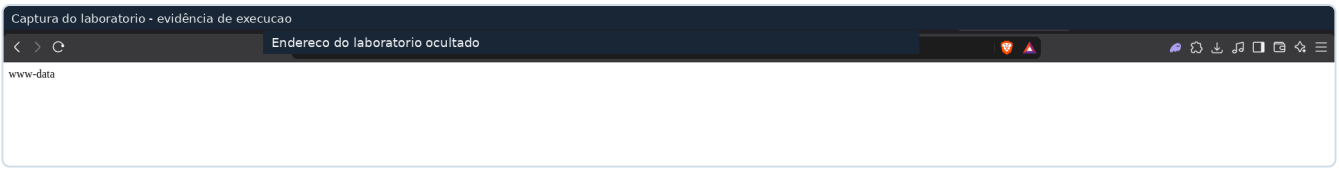


Figura 3 — A resposta `www-data` ao teste documentado com `whoami` indica execução no contexto do servidor web. Endereço ocultado.

4. Limitações e próximos passos

- Este documento **não inclui escopo/autorização formal**, nem detalhes completos do ambiente ou versão das ferramentas utilizadas.
- As capturas registram os resultados, mas não constituem logs completos das requisições e respostas.
- A autenticação e a sequência exata de acesso à área administrativa não foram descritas passo a passo no material original.
- As severidades acima são **avaliações qualitativas**, não pontuações CVSS auditadas.
- Para uma versão técnica mais completa, incluiria contexto de autorização, passos de reprodução apropriados ao laboratório, evidências organizadas com data e recomendações de mitigação testáveis.

5. Aprendizados

O exercício reforçou a importância de distinguir **descobertas de reconhecimento** de **vulnerabilidades comprovadas**, validar hipóteses com evidências reproduzíveis e explicar o impacto de uma falha sem exagerar o nível de acesso obtido. A documentação também é parte do trabalho: uma evidência só ganha valor quando o leitor entende o que ela demonstra.

Uso responsável: conteúdo publicado exclusivamente para fins de estudo e apresentação de habilidades em ambiente educacional. Não reproduza testes em sistemas sem autorização. Nenhuma credencial, hash ou caminho funcional de web shell é fornecido nesta versão.